

Business Logic Vulnerabilities

1. Khái niệm:

Lỗi hỏng logic kinh doanh là những thiếu sót trong thiết kế và triển khai ứng dụng, cho phép kẻ tấn công khai thác các chức năng hợp pháp để đạt được mục tiêu ác ý. Những thiếu sót này thường xuất phát từ việc không dự đoán được các trạng thái ứng dụng bất thường và không xử lý chúng một cách an toàn.

Lỗi hỏng logic không dễ nhận thấy vì chúng thường không xuất hiện trong quá trình sử dụng bình thường của ứng dụng. Các lỗi này cho phép kẻ tấn công thực hiện hành động không mong muốn, như hoàn tất giao dịch mà không qua quy trình thanh toán đúng đắn hoặc thay đổi giá trị quan trọng trong giao dịch.

Business Logic Flow



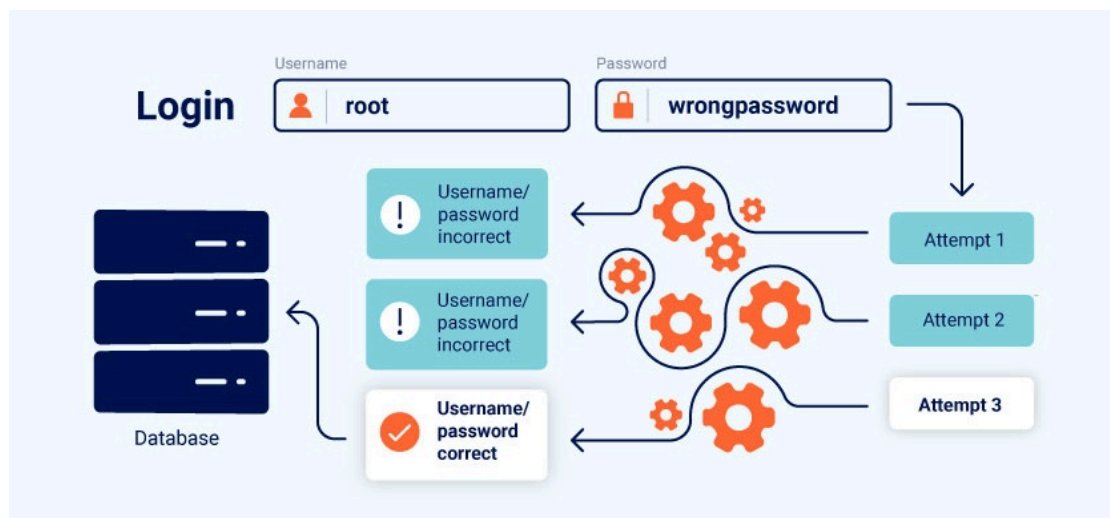
2. Nguyên nhân phát sinh:

Lỗi logic thường do các nhóm phát triển đưa ra giả định sai lầm về cách người dùng sẽ tương tác với ứng dụng. Nếu giả định rằng người dùng chỉ sử dụng trình duyệt để nhập dữ liệu, ứng dụng có thể dựa vào các kiểm soát phía client yếu và dễ bị vượt qua.

3. Tác động:

Tác động của lỗ hổng logic có thể rất khác nhau. Những lỗi này có thể dẫn đến những cuộc tấn công nghiêm trọng, như tăng cường quyền hạn hoặc đánh cắp dữ liệu. Lỗi logic trong các giao dịch tài chính có thể gây ra thiệt hại lớn cho doanh nghiệp.

4. Ví dụ về lỗ hổng logic kinh doanh:



- **Bypass Workflows:** Kẻ tấn công có thể bỏ qua các bước quan trọng trong quy trình kinh doanh.
- **Privilege Escalation:** Kẻ tấn công khai thác lỗi logic để nâng cao quyền hạn của mình.
- **Data Manipulation:** Thay đổi các thông tin quan trọng như giá cả hoặc số lượng sản phẩm.
- **Race Conditions:** Đặt hàng nhiều lần trong khi chỉ có một sản phẩm do hai yêu cầu đến cùng lúc.
- **Invalid State Changes:** Đưa ứng dụng vào trạng thái không hợp lệ để thực hiện các hành động không được phép.
- **Inadequate Validation of Business Rules:** Thiếu kiểm tra đủ các quy tắc kinh doanh cho phép thao tác chức năng.



- **Misconfigured Access Control:** Kiểm soát truy cập không đúng cho phép người dùng không có quyền truy cập vào chức năng nhạy cảm.
- **Abuse of Functionality:** Khai thác các chức năng hợp pháp của ứng dụng một cách không mong muốn.
- **Inconsistent Business Logic:** Các quy tắc kinh doanh không được áp dụng nhất quán, cho phép khai thác điểm yếu.
- **API Abuse:** Thực hiện các cuộc gọi API mà không tuân theo quy tắc ứng dụng đã định nghĩa.

5. Phòng ngừa: Để ngăn chặn lỗ hổng logic, cần:

- Đảm bảo rằng các nhà phát triển và kiểm thử hiểu rõ lĩnh vực mà ứng dụng phục vụ.
- Tránh đưa ra giả định ngầm về hành vi của người dùng.
- Xác định và kiểm tra các giả định liên quan đến trạng thái máy chủ.
- Duy trì tài liệu thiết kế rõ ràng và lưu ý các giả định được đưa ra trong từng giai đoạn phát triển.

6. Tham Khảo

<https://portswigger.net/web-security/logic-flaws>

Mọi thắc mắc hay ý kiến đóng góp vui lòng liên hệ :

Email : r3dctf.info@gmail.com

@Design by R3D CTF Team